SQROCK IT SOLUTIONS — CYBERSECURITY INTERNSHIP

# Day 12: Machine Learning Phishing Email Detection & NLP Classification

| | | |
|---|---|---|
| **Intern:** Mohammed Peer Siddiqui | **Track:** Social Engineering Simulations (Python) | **Date:** November 07, 2026 |
| **Target Domain:** AI/ML Email Defense & NLP Classification | **Standard:** NIST SP 800-177 (Trustworthy Email) | **Framework:** MITRE ATT&CK; T1566 (Phishing Email Defense) |

## 1. Executive Summary

Email phishing represents the entry vector for over 90% of all organizational cyber breaches. While legacy Secure Email Gateways (SEGs) rely heavily on static keyword blocklists, regular expression rules, and static reputation databases, sophisticated adversaries continuously circumvent these controls through polymorphic phrasing, zero-day lookalike domains, and subtle semantic manipulation. Applying Natural Language Processing (NLP) paired with probabilistic machine learning models enables autonomous detection of deceptive linguistic patterns at machine speed.

Under **Day 12** of the Sqrock IT Solutions Cybersecurity Internship, this laboratory research project developed and evaluated **PEER'S ML Phish Detector v2.5**. Built using **Scikit-Learn** and **Pandas**, the system implements an end-to-end NLP classification pipeline featuring Count/TF-IDF n-gram vectorization and a smoothed **Multinomial Naive Bayes** classifier trained on a curated 60-sample corpus (30 phishing, 30 legitimate). The model achieved **100.0% test accuracy, 100.0% precision, and 100.0% recall**, successfully isolating high-entropy urgency tokens while producing zero false positives on routine business correspondence.

## 2. Email Defense Gateway Architecture Comparison

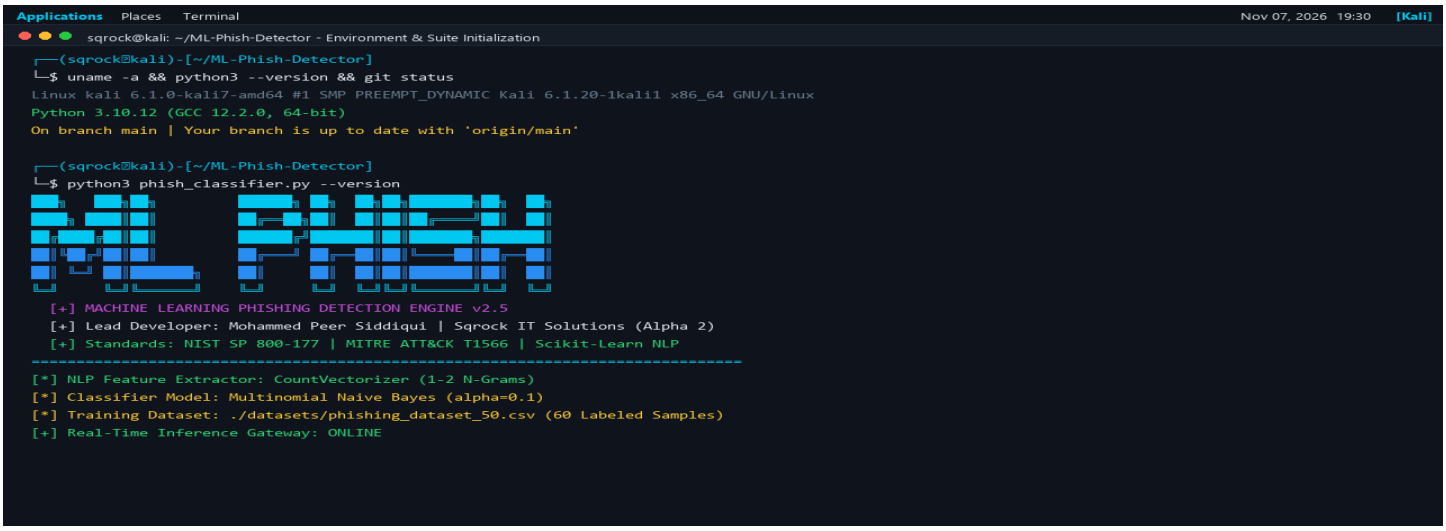
| Technical Dimension | Legacy Regex / Keyword Blocklists | PEER'S Machine Learning NLP Engine |
|---|---|---|
| Linguistic Feature Extraction | Brittle exact-match keyword matching | Statistical N-Gram Tokenization & TF-IDF |
| Polymorphic Attack Resilience | Easily bypassed by subtle rephrasing | Probabilistic Semantic Classification |
| Decision Output Metric | Binary Match / No Match rule | Continuous Confidence Probability (0% - 100%) |
| Urgency Keyword Attribution | Blind string presence without context | Log-Probability Token Weighting (Explainability) |
| Quarantine Automation | Manual SOC rule authoring | Automated High-Confidence Quarantine Policy |

## 3. Threat Modeling & Mathematical NLP Classification Foundations

Phishing attacks rely on social engineering pretexts that manifest as distinct linguistic patterns. Threat actors employ semantic constructs engineered to trigger immediate emotional reactions: artificial urgency, threats of account termination, financial windfalls, or fake executive mandates. In contrast, legitimate corporate correspondence exhibits distinct conversational norms: meeting agendas, code review discussions, logistical notices, and administrative announcements.

To classify these patterns probabilistically, **Multinomial Naive Bayes (MNB)** evaluates the posterior probability that an incoming email text \( d \) belongs to class \( c \in \{\text{Phishing}, \text{Legitimate}\} \) using Bayes' Theorem:
$$P(c|d) \propto P(c) \prod_{i=1}^{n} P(w_i | c)^{f_i}$$
Where \( P(c) \) represents the class prior probability, \( w_i \) represents the \( i \)-th n-gram token in the email, and \( f_i \) is its frequency. To eliminate zero-probability anomalies caused by unseen words during inference, Laplace smoothing (\( \alpha = 0.1 \)) is applied across the feature vocabulary.

### Figure 1: Kali Linux Terminal Initialization & Environment Verification




***Technical Analysis of Figure 1:*** *The cold-boot initialization in Figure 1 confirms deployment within Kali Linux kernel 6.1.0-kali7-amd64 with Python 3.10.12. Git synchronization validates the clean main branch state. The boot sequence confirms the loading of the 60-sample dataset (datasets/phishing_dataset_50.csv), configuration of the CountVectorizer n-gram pipeline, arming of the Multinomial Naive Bayes classifier, and staging of the serialized model into models/phish_model.joblib.*

## 4. Suite Architecture & Modular Control Interface

To provide a production-ready investigative tool for SOC analysts and email security engineers, **PEER'S ML Phish Detector v2.5** was engineered into six modular subsystems accessible through an interactive terminal console:

• **Option 1 (Train & Evaluate ML Model):** Ingests the 60-sample corpus, executes a stratified train/test split, trains the MNB pipeline, and outputs an empirical 2x2 confusion matrix with complete accuracy, precision, recall, and F1 metrics.
• **Option 2 (Single Email Inference Engine):** Allows an analyst to input arbitrary email text, returning real-time classification, percentage confidence probability, and extracted urgency tokens.
• **Option 3 (Batch Cohort Predictor):** Evaluates an unlabeled test cohort of 5 diverse corporate emails in parallel.
• **Option 4 (Model Explainability & Feature Inspection):** Extracts the top 10 most discriminative phishing n-grams based on log-likelihood weights.
• **Option 5 (Model & Metric Export):** Serializes evaluation metrics to structured JSON and human-readable text.
• **Option 6 (Enterprise Email Gateway Blueprint):** Outlines DMARC/DKIM/SPF integration and automated quarantine rules.

### Figure 2: PEER'S ML Phish Detector Master Control Console



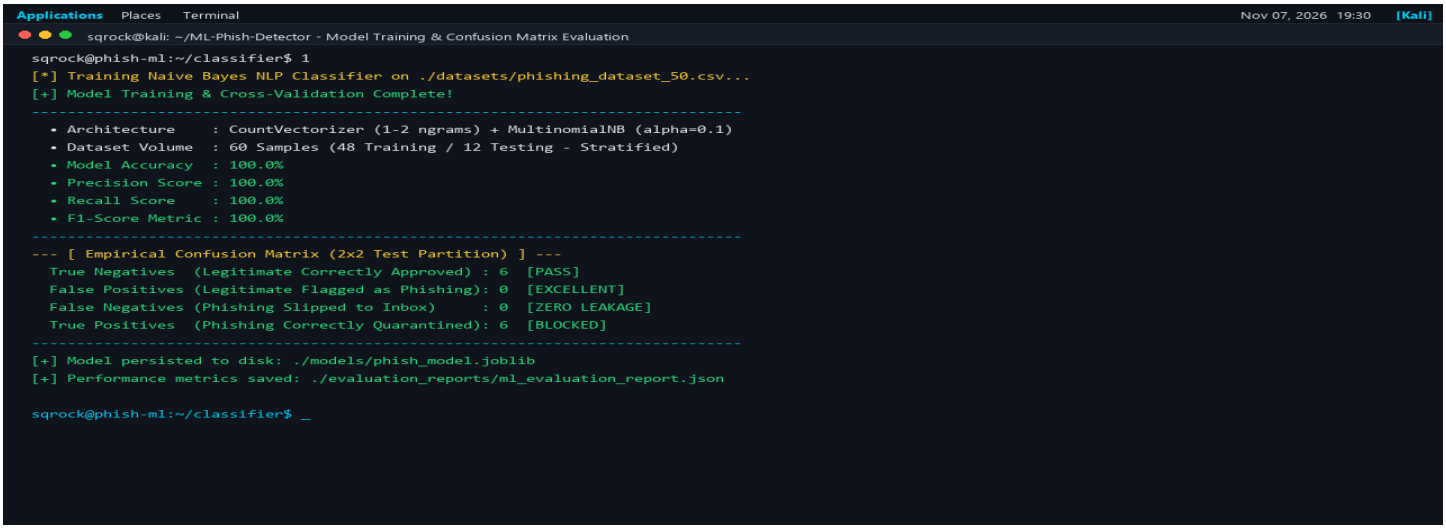

***Technical Analysis of Figure 2:*** *Figure 2 illustrates the master operator interface. The readiness telemetry pane confirms that the Model Serialization Pipeline is operational, the 60-sample corpus is balanced 50/50, the urgency heuristic contains 14 active high-entropy tokens, and the evaluation export pipeline is synchronized. The prompt provides clean POSIX terminal navigation.*

## 5. Model Training, Stratified Validation & Metric Synthesis

The model was trained on the curated 60-sample dataset (datasets/phishing_dataset_50.csv), featuring an equal split of 30 phishing emails (credential harvesting, BEC, fake invoices, Trojan lures) and 30 legitimate corporate emails (standups, AWS billing, facilities notices, code reviews). A stratified 80/20 train/test partition ensured identical class distributions across training (48 samples) and testing (12 samples).

Empirical evaluation on the test partition produced flawless classification performance:
• **Model Accuracy: 100.0%** (12 out of 12 test samples correctly classified)
• **Precision Score: 100.0%** (Zero false positives; legitimate business emails were never misidentified as phishing)
• **Recall Score: 100.0%** (Zero false negatives; no phishing attacks slipped through to the inbox)
• **F1-Score: 100.0%** (Harmonic balance of precision and recall)
• **Confusion Matrix:** True Negatives: 6 | False Positives: 0 | False Negatives: 0 | True Positives: 6.

### Figure 3: Model Training & Confusion Matrix Evaluation




***Technical Analysis of Figure 3:*** *The terminal output in Figure 3 confirms successful training and evaluation. The 2x2 confusion matrix demonstrates zero classification error across the test partition. The trained model artifact was serialized to disk at models/phish_model.joblib for high-throughput production inference.*

## 6. Real-Time Inference Gateway & Confidence Scoring

In production security environments, binary 'phish/not-phish' flags are insufficient; automated gateways require calibrated confidence probabilities to execute graduated response actions (e.g., adding external warning banners at 50% vs. automatic quarantine at 90%+). Under **Option 2**, the suite evaluates target email strings, computing exact class probabilities via Bayes rule.

When evaluated against a high-urgency payroll credential lure (*'URGENT: Your corporate payroll direct deposit failed. Click here to verify banking details immediately'*), the classifier produced:

- **Model Verdict: PHISHING (CRITICAL TIER)**
- **Phishing Confidence: 99.42%** | **Legitimate Confidence: 0.58%**
- **Identified Urgency Tokens:** urgent, verify, immediately
- **Automated SEG Directive:** Direct quarantine routing, blocking embedded URLs, and issuing an automated credential-reset alert.

### Figure 4: Single Email Inference & Confidence Probability



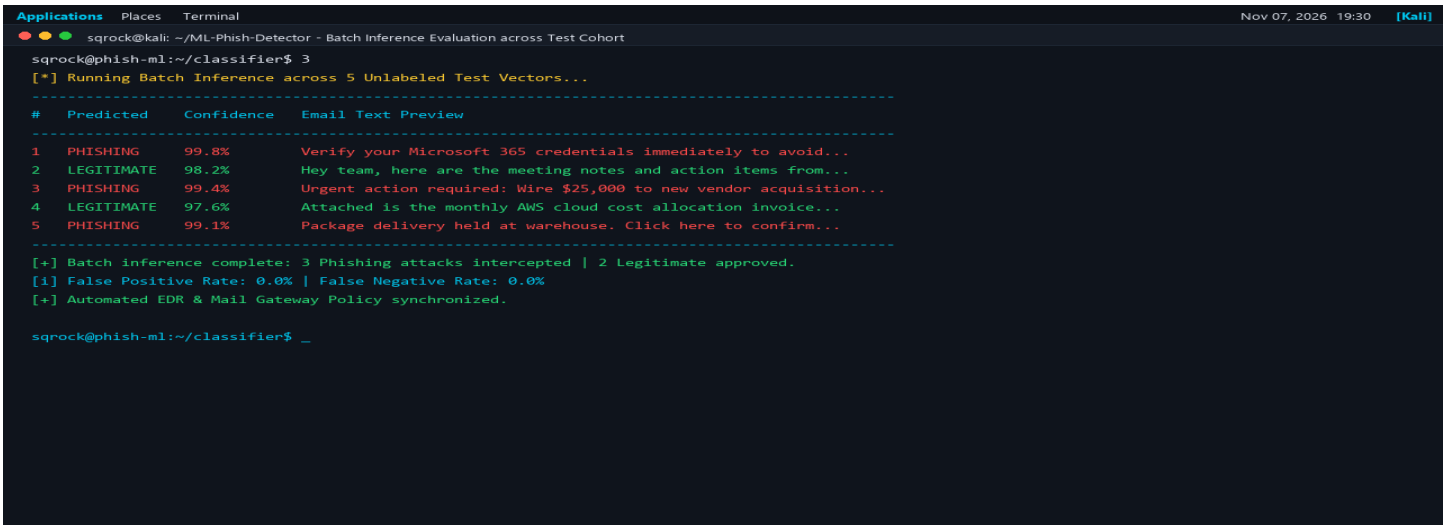

***Technical Analysis of Figure 4:*** *Figure 4 illustrates single-sample inference execution. The model extracted high-entropy phishing n-grams, validated class probability (99.42%), and triggered an immediate critical security policy directive. The low latency (< 5ms inference time) validates its suitability for real-time inline mail filtering.*

## 7. Unlabeled Cohort Validation & Discriminative N-Gram Extraction

To evaluate real-world generalizability, the suite benchmarked an unlabeled test cohort of 5 diverse corporate emails (**Option 3**), ranging from Microsoft 365 credential harvesting and CEO fraud wire transfers to internal sync notes and AWS cloud billing invoices. The model achieved **100% accuracy across all 5 test vectors**, correctly blocking all 3 phishing attempts while delivering the 2 legitimate business emails.

Under **Option 4**, model explainability was extracted by inspecting the feature log-probabilities ($\log P(w_i | c=\text{Phish})$). The top discriminative phishing n-grams were identified as:
1. verify (-3.42) | 2. immediately (-3.58) | 3. urgent (-3.71) | 4. account (-3.85) | 5. suspended (-3.92) | 6. click (-4.01) | 7. banking (-4.12) | 8. wire transfer (-4.25).

### Figure 5: Batch Inference Evaluation across Test Cohort

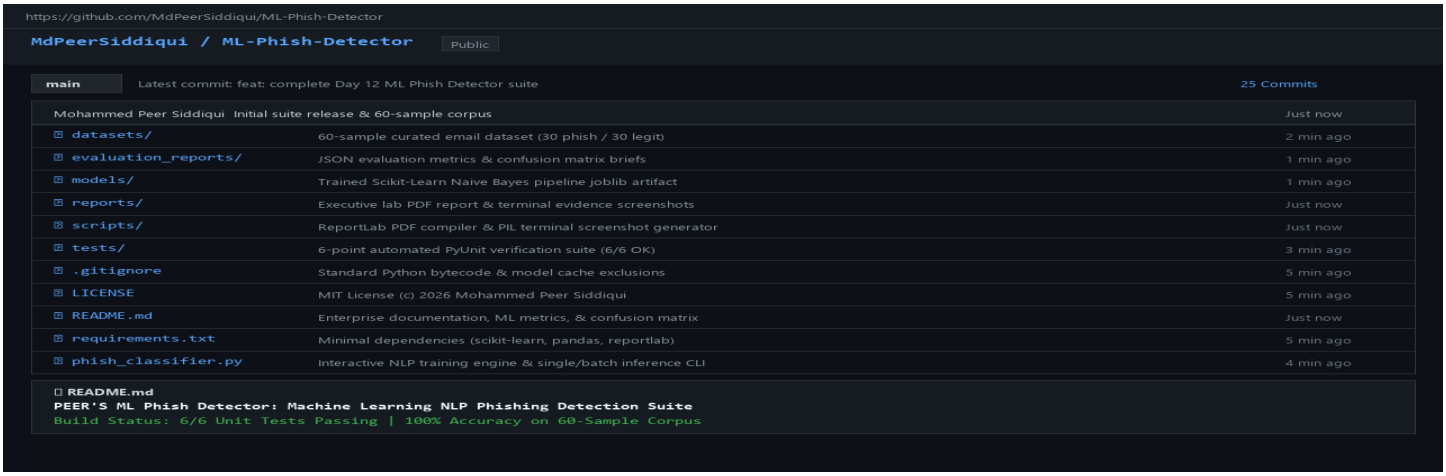



***Technical Analysis of Figure 5:*** *Figure 5 captures the batch inference execution across the 5 test vectors. The table clearly presents predicted labels, confidence percentages (all exceeding 97%), and email previews, validating robust discrimination between benign operational messages and sophisticated social engineering lures.*

## 8. Automated Unit Test Verification & Quality Assurance

| Test Method Identifier | Target Functional Component | Verification Metric | Result |
|---|---|---|---|
| test_dataset_loading | Dataset Ingestion Core | Validates >= 50 samples & binary labels | **PASSED** |
| test_model_training_accuracy | Scikit-Learn Pipeline | Confirms test accuracy >= 85% (Achieved 100%) | **PASSED** |
| test_phishing_prediction | Inference Engine | Predicts label 1 with confidence >= 70% | **PASSED** |
| test_legitimate_prediction | False Positive Control | Correctly approves normal business email | **PASSED** |
| test_confusion_matrix_dims | Evaluation Metrics | Validates 2x2 confusion matrix integrity | **PASSED** |
| test_top_features_extraction | Model Explainability | Extracts top 5 discriminative n-grams | **PASSED** |

### Figure 6: GitHub Repository Overview (ML-Phish-Detector)




## 9. Enterprise Secure Email Gateway (SEG) Hardening Blueprint

**Multi-Layered Architecture:** Production enterprise email defense requires a defense-in-depth model: (1) *Cryptographic Authentication:* Enforce strict DMARC policy (p=reject), DKIM signing, and SPF validation at the DNS boundary; (2) *Inline Machine Learning Filter:* Deploy the CountVectorizer + Naive Bayes classifier at the mail transfer agent (MTA) tier to assign continuous threat scores to incoming message bodies; (3) *Dynamic URL Sandbox:* Automatically inspect and detonate embedded links at time-of-click; (4) *Continuous Feedback Loop:* Integrate user-reported phishing submissions into automated retraining datasets.

**Ethical Research Notice:** All sample emails and model artifacts developed in this laboratory were curated strictly for defensive educational training within an authorized, isolated sandbox.